# FICHE 20 – ANALYSE DE RISQUES

### Identifier les risques et évaluer leur vraisemblance et leur gravité pour mettre en place les mesures de sécurité appropriées.

En parallèle de la mise en conformité aux précautions élémentaires présentées dans ce guide, il est pertinent, voire obligatoire selon la criticité des traitements, de réaliser des analyses de risques relative à la protection des données. Ces analyses permettent de décider des mesures de sécurité complémentaires, adaptées au contexte, permettant de limiter l'impact sur les personnes concernées par le traitement.

## Les précautions élémentaires

- Identifier les traitements de données personnelles pour lesquels **une analyse d'impact relative à la protection des données (AIPD)[87] doit obligatoirement être menée selon le RGPD[88]**. Une AIPD comporte non seulement une partie dédiée à la réflexion sur les risques, objet de la présente fiche, mais également une partie dédiée au volet juridique des traitements de données personnelles.
- Mener une analyse de risques[89], même minimale, selon les trois étapes suivantes :

1. **Recenser les traitements** de données personnelles, automatisés ou non, les données traitées (ex. : fichiers clients, contrats) et les supports sur lesquels ces traitements reposent :
   - les matériels (ex. : serveurs, ordinateurs portables, disques durs) ;
   - les logiciels (ex. : systèmes d'exploitation, logiciels métier) ;
   - les ressources d'informatique en nuage (*cloud*) utilisés (ex. : SaaS, PaaS, IaaS) ;
   - les canaux de communication logiques ou physiques (ex. : fibre optique, Wi-Fi, Internet, échanges verbaux, coursiers) ;
   - les supports papier (ex. : documents imprimés, photocopies) ;
   - les locaux et installations physiques où se situent les éléments précédemment cités (ex. : locaux informatiques, bureaux).

Cette étape mérite d'être menée indépendamment de toute analyse de risques (voir la fiche n°1 - Piloter la sécurité des données).

2. **Apprécier les risques** engendrés par chaque traitement :
   a. **Identifier les impacts potentiels** sur les droits et libertés des personnes concernées, pour les trois évènements redoutés suivants :
      - **accès illégitime à des données** (ex. : usurpation d'identité consécutive à la divulgation des fiches de paie de l'ensemble des salariés d'une entreprise) ;
      - **modification non désirée de données** (ex. : accusation à tort d'une personne d'une faute ou d'un délit suite à la modification de journaux d'accès) ;
      - **disparition temporaire ou définitive de données** (ex. : non-détection d'une interaction médicamenteuse du fait de l'impossibilité d'accéder au dossier électronique du patient).

87 « Ce qu'il faut savoir sur l'analyse d'impact relative à la protection des données (AIPD) », cnil.fr

88 Article 35 du RGPD.

89 Le vocabulaire utilisé dans la description suivante est tiré des guides AIPD publiés par la CNIL (voir « Les guides AIPD (analyse d'impact relative à la protection des données) », cnil.fr).